ACCESS CONTROL

What is access control ?

- Controlling access to information systems its associated networks to preserve confidentiality, integrity, and normal availability of information, to minimize threats, vulnerabilities, and risks
- **Threat**: An event or activity that has the potential to cause harm to the information systems or networks
- **Vulnerability:** A weakness or lack of a safeguard that can be exploited by a threat, causing harm to the information systems or networks
- **Risk:** The potential for harm or loss to an information system or network; the probability that a threat will materialize

What is access control ? - continued

- It enables an authority to control access to areas and resources in a given physical facility or computer-based information system.
- It includes authentication, authorization and audit. It also includes measures such as physical devices, including biometric scans and metal locks, hidden paths, digital signatures, encryption, social barriers, and monitoring by humans and automated systems.
- The entities that can perform actions in the system are called subjects, and the entities representing resources to which access may need to be controlled are called objects. Subjects and objects should both be considered as software entities and as human users

Access Control Classes

The classes are based on capabilities and access control lists (ACLs).

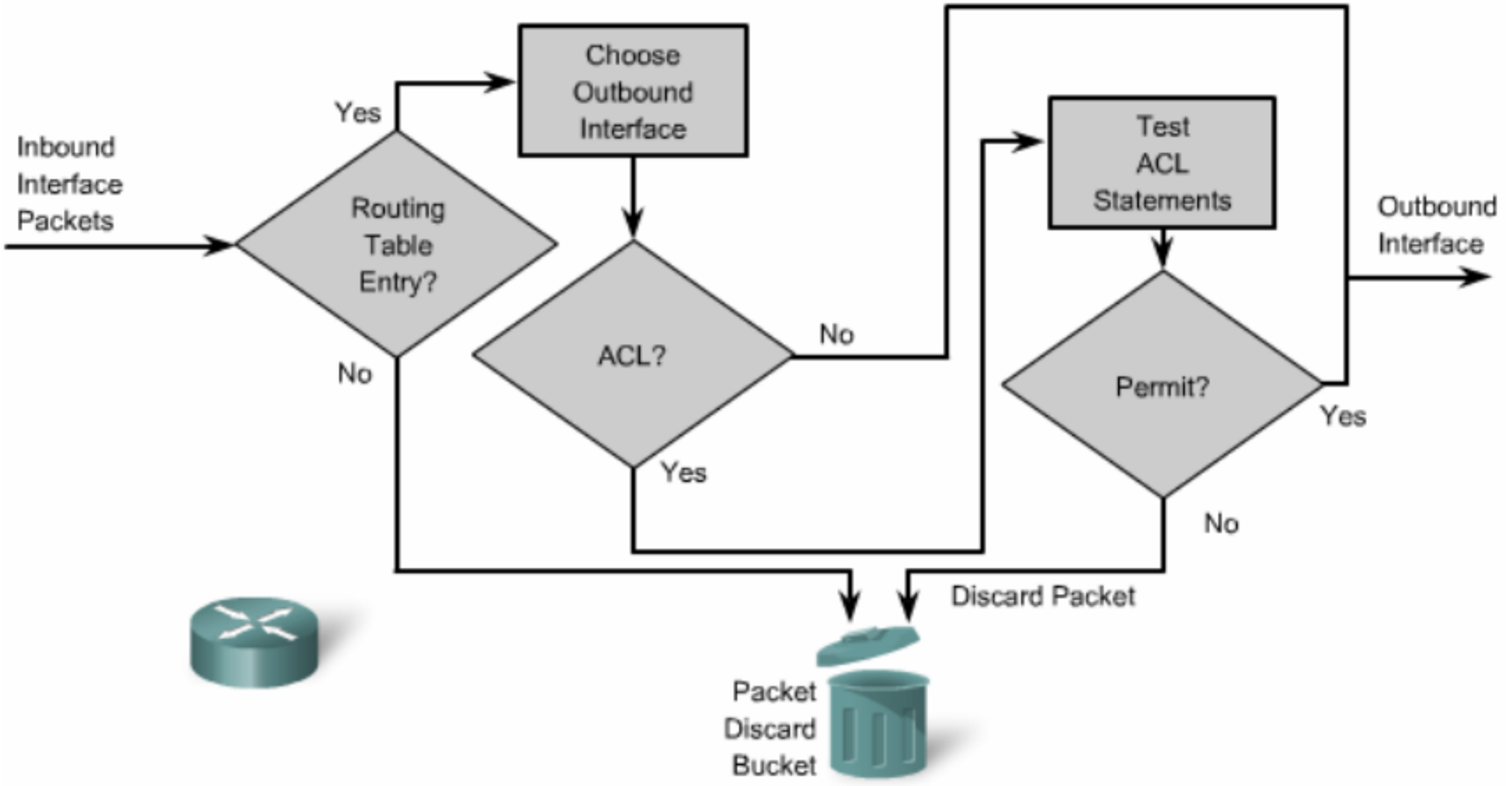
- **Capability-based model**
  - Holds an unforgeable reference or *capability* to an object providing access to the object
  - Access is conveyed to another party by transmitting such a capability over a secure channel.
- **ACL-based model:** a subject's access to an object depends on whether its identity is on a list associated with the object

ACL Configuration Guidelines

An administrator can develop Access Control Lists on Systems

- ACLs are created globally and then applied to interfaces
- ACLs filter traffic going through the router, or traffic to and from the router, depending on how it is applied
- Only one ACL per interface, per protocol, per direction
- Standard or extended indicates the information that is used to filter packets
- ACLs are process top-down. The most specific statements must go at the top of the list
- All ACLs have an implicit “deny all” statement at the end, therefore every list must have at least one permit statement to allow any traffic to pass

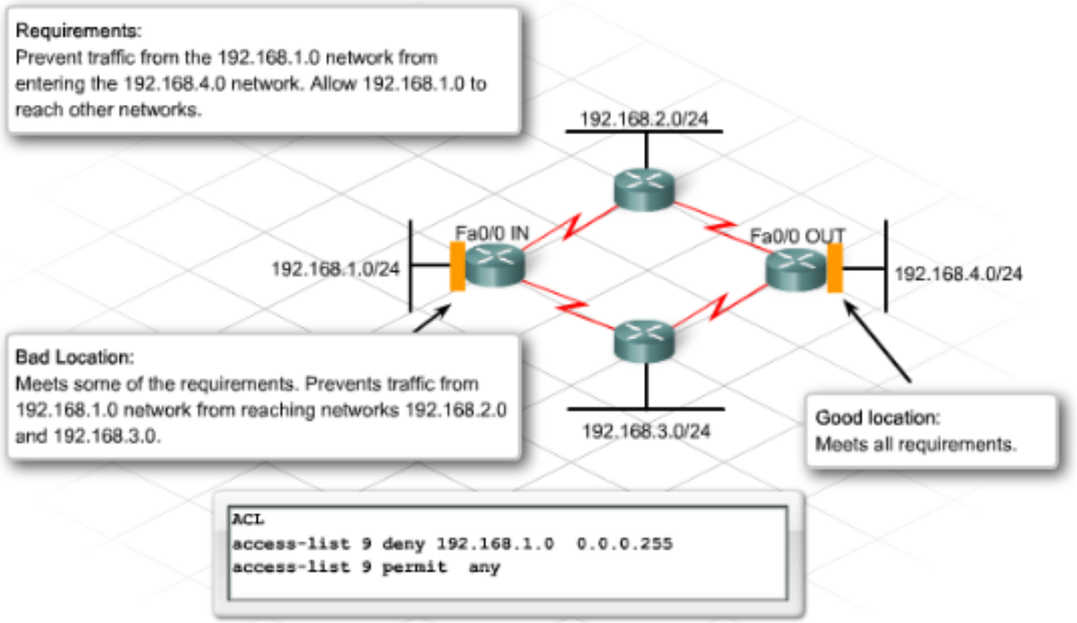
How ACLs Work



Inbound ACL **Outbound ACL**

ACL Placement

Standard ACLs should be placed as close to the destination as possible. Standard ACLs filter packets based on the source address only. If placed too close to the source, it can deny all traffic, including valid traffic.



Extended ACLs should be placed on routers as close as possible to the source that is being filtered. If placed too far from the source being filtered, there is inefficient use of network resources.

What is access control ? - continued

- Controls should mitigate risk and reduce the potential for loss by being:
  - Preventive
  - Detective and/or
  - Corrective
- Access Controls measures can be administrative, logical or technical, and physical, to ensure:
  - Separation of duties
  - Least privilege for people to exploit
  - Information to be available on need to know basis

Control Measure Types

- **Administrative**: policies and procedures, security awareness training, background checks, work habit checks, a review of vacation history, and increased supervision.
- **Logical or technical:** restriction of access to systems and the protection of information. Examples of these types of controls are encryption, smart cards, access control lists, and transmission protocols.
- **Physical**: guards and building security in general, such as the locking of doors, the securing of server rooms or laptops, the protection of cables, the separation of duties, and the backing up of files.

Access Control Examples

Controls	Administrative	Technical	Physical
Directive	Policy	Warning Banner	'Do Not Enter'
Deterrent	Demotion	Violation Reports	'Beware of Dog'
Preventive	User Registration	Passwords, Tokens	Fences, Bollards
Detective	Report Reviews	Audit Logs, IDS	Sensors, CCTV
Corrective	Employee Termination	Connection Management	Fire Extinguisher
Recovery	DRP	Backups	Reconstruct, Rebuild
Compensating	Supervision, Job Rotation	Keystroke Logging	Layered Defenses

Models for Controlling Access

- By a subject such as an active entity like an individual or process to an object or an entity by setting up access rules. These rules can
- Three categories access rules:
  - Mandatory Access Control
  - Discretionary Access Control
  - Non-Discretionary Access Control

Mandatory Access Control

- MAC: restricts the individual ability to access resources.
- The authorization of a subject’s access to an object is dependent upon labels, which indicate the subject’s clearance, and the classification or sensitivity of the object.
- Resource owners have to grant or deny access to resource objects in a file system.
- Criteria are defined by the system administrator, strictly enforced by the operating system (OS) or security kernel, and are unable to be altered by end users
- The control works by assigning a classification label to each file system object. Classifications include confidential, secret and top secret
- Majorly used in sectors like: government offices, military, health care, financial, engineering projects, etc

Mandatory Access Control

Mandatory Access Control

Mandatory Access Control

Advantages

- High-level data protection, with no room for any leakage.
- Centralized Information, where once categories are set, it cannot be de-categorized by anyone other than the head administrator.
- Privacy, as no one other than administrator can make changes in category or list of users' accesses to any category.

Disadvantages

- It can make working chaotic, as some data may need to be shared among co-workers in the same organization.
- It requires regular updating when new data is added or old data is deleted.
- Lack of operationally flexible.

Discretionary Access Control

- The subject has authority, within certain limitations, to specify what objects can be accessible, by using access control lists can be used.
- A user with access to a certain level of data can give access to the same level of data to someone else based on their judgement and choice.
- The flow of data much easier and a lot more user-friendly than any other system. But, contrary to the flexibility it offers, this system is also less secure as the flow of information can’t be administered regularly.
- A subject has the discretion to specify what resources certain users are permitted to access
- Within certain limitations, access control to certain objects can be altered, this is termed as a user-directed discretionary access control. An identity based access control is a type of discretionary access control that is based on an individual’s identity. In some instances, a hybrid approach is used, which combines the features of user-based and identity-based discretionary access control.

Discretionary Access Control

Discretionary Access Control

Advantages

- Managing data and permissions is easier
- System allows any user with access to certain information to grant access to others as well
- Sharing of data is much easier as the administration does not need to interfere whenever a piece of information is needed

Disadvantages

- As access can be given from one person to another, data is not very well secured
- The system is not centralized, the only way administration can monitor data flow is by going through ACL

Non-Discretionary Access Control (NDAC)

- A central authority determines what subjects can have access to certain objects based on the organizational security policy.
- The controls may be based on the individual's role in the organization **(role-based)** or the subject's responsibilities and duties **(task-based).**
- Where personnel changes are frequent, non-discretionary access control is useful as the controls are based on the individual's role or title within the organization.
- Another type of non-discretionary access control is **lattice-based access control**, where a lattice model is applied.
- In a lattice model, there are pairs of elements that have the least upper bound of values and greatest lower bound of values.
- To apply this concept to access control, the pair of elements is the subject and object, and the subject has the greatest lower bound and the least upper bound of access rights to an object.

Other Access Controls

- **Context-dependent:** Determined by environment factors like location, time of day, and/or context of the data previous access history, associated with the resource.
- **Temporal Access Control**: Dependent on the hours of operation
- **Role-based Access Control**: Depends on the user roles, privacy-aware policies, on organization for economic co-operation and development user roles and needs

Other Access Controls

- Access control techniques: Access control techniques are sometimes categorized as either discretionary or non-discretionary. The three most widely recognized models are Discretionary Access Control (DAC), Mandatory Access Control (MAC), and Role Based Access Control (RBAC). MAC and RBAC are both non-discretionary.
- Attribute-based Access Control: In attribute-based access control, access is granted not based on the rights of the subject associated with a user after authentication, but based on attributes of the user. The user has to prove so called claims about his attributes to the access control engine. An attribute-based access control policy specifies which claims need to satisfied in order to grant access to an object. For instance the claim could be "older than 18" . Any user that can prove this claim is granted access. Users can be anonymous as authentication and identification are not strictly required. One does however require means for proving claims anonymously. This can for instance be achieved using Anonymous credentials.

Control Combinations:

- **Preventive/administrative**: organizational policies, strict hiring practices, employment agreements, labeling of sensitive materials, increased supervision, sign-up procedures, etc
- **Preventive/technical:**
  - logical Protocols, encryption, smart cards, etc as
  - technical mechanisms protect information and passwords from disclosure, while biometrics apply technologies such as fingerprint, iris scans, etc to authenticate individuals.
  - Constrained user interfaces limit the functions that a user can select
  - shells limit the system-level commands
  - Database views restrict the information users access in a database
  - limited keypads provide only a small number of keys users can use

Control Combinations (Continued)

- **Preventive/physical:** security perimeter like fence, man-trap, etc defines the area intended to have restricted the physical access
- **Detective/administrative:** organizational policies, behavior awareness, job rotation, the sharing of responsibilities, and reviews of audit records
- **Detective/technical:** reveal the violations of security policy by using technical means using intrusion detection, signatures of unauthorized access episodes, audit records, etc
- **Detective/physical:** evaluation of the input from motion detectors, thermal detectors, and video cameras, etc, to determine whether a real threat exists.

Access Control Technologies

- **Single sign-on**
- **Kerberos**
- SESAME
  - An extension of Kerberos for use with applications
  - Symmetric and asymmetric
  - Distributed authentication
- Directory services
  - Lightweight Directory Access Protocol (LDAP)
  - Network Information Services (NIS)
  - Domain Name System (DNS)
- Security domains
  - Hierarchical domain relationship
  - Equivalent classes of subjects
- Web Portal Access
  - Federated login
  - Portlet

Single Sign-On

- Single Sign-On (SSO) addresses the cumbersome situation of logging on multiple times to access different resources.
- User provides one ID and password per work session and is automatically logged on to all the required applications.
- It involves:
  1. User enters userID and password
  2. UserID and passwords is transmitted to Authentication Server for detail verification
  3. Authentication Server verifies user's identity using stored data
  4. Authentication Server authorizes access to requested resource.
- Single sign-on (SSO) is a property of access control of multiple, related, but independent software systems. Single sign-off is the reverse property whereby a single action of signing out terminates access to multiple software systems.
- As different applications and resources support different authentication mechanisms, single sign-on has to internally translate to and store different

Single Sign-on Kerberos

- Kerberos is a computer network authentication protocol, which allows nodes communicating over a non-secure network to prove their identity to one another in a secure manner.
- Its symmetric key cryptography, Kerberos authenticates clients to other entities on a network of which a client requires services.
- It is also a suite of free software published by MIT that implements this protocol. Its designers aimed primarily at a client–server model, and it provides mutual authentication — both the user and the server verify each other's identity. Kerberos protocol messages are protected against eavesdropping and replay attacks.
- Optionally it use public-key cryptography by utilizing asymmetric key cryptography during certain phases of authentication

Kerberos

- Kerberos uses as its basis the symmetric Needham-Schroeder protocol. It makes use of a trusted third party, termed a key distribution center (KDC), which consists of two logically separate parts: an Authentication Server (AS) and a Ticket Granting Server (TGS). Kerberos works on the basis of "tickets" which serve to prove the identity of users.
- The KDC maintains a database of secret keys; each entity on the network — whether a client or a server — shares a secret key known only to itself and to the KDC. Knowledge of this key serves to prove an entity's identity. For communication between two entities, the KDC generates a session key which they can use to secure their interactions.
- The security of the protocol relies heavily on participants maintaining loosely synchronized time and on short-lived assertions of authenticity called *Kerberos tickets*.

Kerberos - Continued

- The client authenticates itself to the Authentication Server and receives a ticket. (All tickets are time-stamped.)
- It then contacts the Ticket Granting Server, and using the ticket it demonstrates its identity and asks for a service.
- If the client is eligible for the service, then the Ticket Granting Server sends another ticket to the client.
- The client then contacts the Service Server, and using this ticket it proves that it has been approved to receive the service.

Basic Kerberos Operation Principles

- ★ The Key Distribution Center (KDC) knows the secret keys of all clients and servers on the network.
- ★ The KDC initially exchanges information with the client and server by using these secret keys.
- ★ Kerberos authenticates a client to a requested service on a server through TGS and by issuing temporary symmetric session keys for communications between the client and KDC, the server and the KDC, and the client and server.
- ★ Communication then takes place between the client and the server by using those temporary session keys.

Kerberos: Disadvantages

- Single point of failure: It requires continuous availability of a central server. When the Kerberos server is down, no one can log in. This can be mitigated by using multiple Kerberos servers and fallback authentication mechanisms.
- Kerberos requires the clocks of the involved hosts to be synchronized. The tickets have a time availability period and if the host clock is not synchronized with the Kerberos server clock, the authentication will fail. The default configuration requires that clock times are no more than five minutes apart. In practice Network Time Protocol daemons are usually used to keep the host clocks synchronized.
- The administration protocol is not standardized and differs between server implementations.
- Since all authentication is controlled by a centralized KDC, compromise of this authentication infrastructure will allow an attacker to

Access to Data

Implementations

- Mandatory
- Temporal
- Discretionary
- Role
- Rule
- Content
- Privacy

Descriptions

- List
- Matrix
- Capabilities
- Non-discretionary
- Constraints
- Centralized
- Decentralized

Access Conrol Administration

- Access Control Administration will work out how the organization will administrator access control: Centralized or Distributed.
- Terminal Access Controller Access-Control System (TACACS) is a remote authentication protocol that is used to communicate with an authentication server commonly used in UNIX networks.
- TACACS allows a client to accept a username and password and send a query to a TACACS authentication server, sometimes called a TACACS daemon or XTACACS. This server was normally a program running on a host. The host would determine whether to accept or deny the request and send a response back. The TIP (routing node accepting dial-up line connections, which the user would normally want to log in into) would then allow access or not, based upon the response.
- TACACS+ and RADIUS have generally replaced TACACS. TACACS+ is an entirely new protocol and not compatible with TACACS or XTACACS. TACACS+ uses the Transmission Control Protocol (TCP) and RADIUS uses

Intrusion Detection System

- An IDS is a device (or application) that monitors network and/or system activities for malicious activities or policy violations and produces reports to a Management Station.[
- Intrusion prevention is the process of performing intrusion detection and attempting to stop detected possible incidents.
- Intrusion detection and prevention systems (IDPS) are primarily focused on identifying possible incidents, logging information about them, attempting to stop them, and reporting them to security administrators.

Intrusion Detection System

- For the purpose of dealing with IT, there are two main types of IDS's: network-based and host-based IDS.
- In a network-based intrusion-detection system (NIDS), the sensors are located at choke points in the network to be monitored, often in the demilitarized zone (DMZ) or at network borders. The sensor captures all network traffic and analyzes the content of individual packets for malicious traffic.
- In a host-based system, the sensor usually consists of a software agent, which monitors all activity of the host on which it is installed, including file system, logs and the kernel. Some application-based IDS are also part of this category.

Access Control Assurance and Penetration Testing

- Assurance
  - Audit trail monitoring
  - Vulnerability assessment tools
- Penetration Testing
  - Definition
  - Areas to test
  - Methods of testing
  - Testing procedures
  - Testing hazards

Areas to Test

- Application security
- Denial of service (DoS)
- War dialing
- Wireless penetration
- Social engineering
- PBX and IP telephony

Penetration Testing Methods and Steps

- External
  - Zero-knowledge (blind)
  - Partial-knowledge
- Internal
  - Full-knowledge
  - Targeted
  - Blind
  - Double-blind
- Steps
  - Discovery
  - Enumeration
  - Vulnerability mapping
  - Exploitation

Testing Hazards and Reporting

- Production interruption
  - Application abort
  - System crash
- Documentation
  - Identified vulnerabilities
  - Countermeasure effectiveness
  - Recommendations

Access Control

- Discretionary access control: (DAC) is an access policy determined by the owner of an object. The owner decides who is allowed to access the object and what privileges they have.
- Two important concepts in DAC are
  - File and data ownership: Every object in the system has an *owner*. In most DAC systems, each object's initial owner is the subject that caused it to be created. The access policy for an object is determined by its owner.
  - Access rights and permissions: These are the controls that an owner can assign to other subjects for specific resources.
- Access controls may be discretionary in ACL-based or capability-based access control systems. (In capability-based systems, there is usually no explicit concept of 'owner', but the creator of an object has a similar degree of control over its access policy.)